

Enterprise Database Infrastructure Administration Lab

Design, Deployment, Security Hardening, Backup, Replication and
Monitoring of PostgreSQL Infrastructure on Linux

David Gottlieb SITTI
<https://www.linkedin.com/in/davidgottliebsitti/>

SUMMARY

DATABASE SECURITY HARDENING.....	2
----------------------------------	---

DATABASE SECURITY HARDENING

I. Objective

The goal of this deliverable is to transform the PostgreSQL deployment into a hardened enterprise database platform.

- At the end of this phase :
- Linux administration access is hardened
- PostgreSQL authentication is secured
- Database communications are encrypted
- Database auditing is enabled
- Access control is enforced
- Security logging is centralized
- Unauthorized access attempts can be detected

This phase aligns strongly with the responsibilities of a System Administrator, DBA, and Cybersecurity Engineer.

II. Security Architecture

1. Current State

Client → PostgreSQL

2. Target State

Client

|

TLS Encryption

|

Firewall Rules

|

Authentication Controls

|

Authorization Controls

|

Audit Logging

|

PostgreSQL

III. Linux Hardening – SSH Security

Perform on :

- pg-primary
- pg-replica

- monitoring
- db-admin

Backup SSH Configuration :

```
sudo cp /etc/ssh/sshd_config \
/etc/ssh/sshd_config.bak
```

Edit SSH Configuration :

```
sudo nano /etc/ssh/sshd_config
```

Modify :

```
PermitRootLogin no
PasswordAuthentication yes
MaxAuthTries 3
LoginGraceTime 30
ClientAliveInterval 300
ClientAliveCountMax 2
X11Forwarding no
AllowTcpForwarding no
```

Verify Configuration :

```
sudo sshd -t
```

Restart SSH :

```
sudo systemctl restart ssh
```

Verify :

```
sudo systemctl status ssh
```

```
root@pg-primary:~# systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: enabled)
   Active: active (running) since Sat 2026-06-13 12:39:11 UTC; 10s ago
   TriggeredBy: ● ssh.socket
     Docs: man:sshd(8)
           man:sshd_config(5)
   Process: 39708 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
   Main PID: 39710 (sshd)
     Tasks: 1 (limit: 4543)
    Memory: 1.2M (peak: 1.5M)
       CPU: 16ms
   CGroup: /system.slice/ssh.service
           └─39710 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

juin 13 12:39:11 pg-primary systemd[1]: Starting ssh.service - OpenBSD Secure Shell server...
juin 13 12:39:11 pg-primary sshd[39710]: Server listening on 0.0.0.0 port 22.
juin 13 12:39:11 pg-primary sshd[39710]: Server listening on :: port 22.
juin 13 12:39:11 pg-primary systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
root@pg-primary:~#
```

IV. SSH Key-Based Authentication

This is standard practice in production environments.

Generate Key Pair on db-admin

```
ssh-keygen -t ed25519
```

Deploy Public Key

- For pg-primary :
- `ssh-copy-id david@pg-primary`
- Repeat for :
pg-replica
monitoring
client-test

Test

```
ssh david@pg-primary
```

```
root@db-admin:~# ssh gottlieb@pg-primary
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-124-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of sam. 13 juin 2026 13:11:41 UTC

System load:  0.0          Processes:      230
Usage of /:   36.6% of 18.53GB   Users logged in: 1
Memory usage: 8%          IPv4 address for ens33: 192.168.137.158
Swap usage:  0%

La maintenance de sécurité étendue pour Applications n'est pas activée.
0 mise à jour peut être appliquée immédiatement.

Activez ESM Apps pour recevoir des futures mises à jour de sécurité supplémentaires.
Visitez https://ubuntu.com/esm ou exécutez : sudo pro status

Last login: Sat Jun 13 13:07:52 2026 from 192.168.10.10
gottlieb@pg-primary:~$
gottlieb@pg-primary:~$
```

V. Firewall Hardening

1. View Existing Rules

```
sudo ufw status numbered
```

2. pg-primary

Keep only :

```
sudo ufw allow 22/tcp
```

```
sudo ufw allow 5432/tcp
```

3. pg-replica

Keep only :

```
sudo ufw allow 22/tcp
```

```
sudo ufw allow 5432/tcp
```

4. monitoring

```
sudo ufw allow 22/tcp
sudo ufw allow 3000/tcp
sudo ufw allow 9090/tcp
```

5. Verify

```
sudo ufw status verbose
```

VI. PostgreSQL Authentication Hardening

1. Verify Password Encryption

Connect :

```
sudo -u postgres psql
```

Check :

```
SHOW password_encryption;
```

```
root@pg-primary:~# sudo -u postgres psql
psql (16.14 (Ubuntu 16.14-0ubuntu0.24.04.1))
Type "help" for help.

postgres=# SHOW password_encryption;
password_encryption
-----
scram-sha-256
(1 row)

postgres=#
```

2. If Not Enabled

Edit :

```
sudo nano /etc/postgresql/*/main/postgresql.conf
```

Add :

```
password_encryption = scram-sha-256
```

Restart :

```
sudo systemctl restart postgresql
```

VII. Harden pg_hba.conf

Edit :

```
sudo nano /etc/postgresql/*/main/pg_hba.conf
```

Replace broad rules.

Instead use :

```
host company_prod app_user 192.168.10.40/32 scram-sha-256
host replication backup_operator 192.168.10.21/32 scram-sha-256
host all dba_admin 192.168.10.10/32 scram-sha-256
```

```
# Allow replication connections from localhost, by a user with the
# replication privilege.
host    company_prod    app_user    192.168.10.40/32    scram-sha-256
host    replication    replicator  192.168.10.21/32    scram-sha-256
host    all            dba_admin   192.168.10.10/32    scram-sha-256
```

Explanation :

Account	Source
app_user	client-test
dba_admin	db-admin
replicator	pg-replica

Principle :

Least Privilege Access.

Restart :

```
sudo systemctl restart postgresql
```

VIII. Password Rotation Exercise

Simulate enterprise password rotation.

Connect :

```
sudo -u postgres psql
```

Rotate password :

```
ALTER ROLE app_user
PASSWORD 'NewStrongPassword2026!';
```

IX. TLS Encryption

One of the most important DBA skills.

1. Verify Existing Certificates

```
sudo ls -l \
/etc/ssl/certs/ssl-cert-snakeoil.pem
```

Ubuntu usually provides default certificates.

2. Enable SSL

Edit :

```
sudo nano /etc/postgresql/*/main/postgresql.conf
```

Verify :

```
ssl = on
```

Check :

```
ssl_cert_file
```

```
ssl_key_file
```

Exemple :

```
ssl_cert_file='/etc/ssl/certs/ssl-cert-snakeoil.pem'
```

```
ssl_key_file='/etc/ssl/private/ssl-cert-snakeoil.key'
```

```
# - SSL -

ssl = on
#ssl_ca_file = ''
ssl_cert_file = '/etc/ssl/certs/ssl-cert-snakeoil.pem'
#ssl_crl_file = ''
#ssl_crl_dir = ''
ssl_key_file = '/etc/ssl/private/ssl-cert-snakeoil.key'
#ssl_ciphers = 'HIGH:MEDIUM:+3DES:!aNULL' # allowed SSL ciphers
#ssl_prefer_server_ciphers = on
#ssl_ecdh_curve = 'prime256v1'
#ssl_min_protocol_version = 'TLSv1.2'
#ssl_max_protocol_version = ''
#ssl_dh_params_file = ''
#ssl_passphrase_command = ''
#ssl_passphrase_command_supports_reload = off
```

Restart :

```
sudo systemctl restart postgresql
```

Verify :

```
sudo -u postgres psql
```

Inside :

```
SHOW ssl;
```

```
root@pg-primary:~# systemctl restart postgresql
root@pg-primary:~# sudo -u postgres psql
psql (16.14 (Ubuntu 16.14-0ubuntu0.24.04.1))
Type "help" for help.

postgres=# SHOW ssl;
 ssl
-----
 on
(1 row)

postgres=#
```

X. TLS Connection Validation

From client-test

Connect :

```
psql "host=pg-primary \
dbname=company_prod \
user=app_user \
sslmode=require"
```

Verify :

```
SELECT *
FROM pg_stat_ssl;
```

```

root@client-test:~# psql "host=pg-primary \
dbname=company_prod \
user=app_user \
sslmode=require"
Password for user app_user:
psql (16.14 (Ubuntu 16.14-0ubuntu0.24.04.1))
SSL connection (protocol: TLSv1.3, cipher: TLS_AES_256_GCM_SHA384, compression: off)
Type "help" for help.

company_prod=> SELECT *
company_prod-> FROM pg_stat_ssl;
  pid | ssl | version | cipher | bits | client_dn | client_serial | issuer_dn
-----+-----+-----+-----+-----+-----+-----+-----
 60167 | t   | TLSv1.3 | TLS_AES_256_GCM_SHA384 | 256 |           |               |
(1 row)

company_prod=>

```

XI. PostgreSQL Logging Configuration

Edit :

```
sudo nano /etc/postgresql/*/main/postgresql.conf
```

Enable :

```

logging_collector = on
log_directory = '/var/log/postgresql'
log_filename = 'postgresql.log'
log_connections = on
log_disconnections = on
log_duration = on
log_statement = 'ddl'

```

Restart :

```
sudo systemctl restart postgresql
```

Verify :

```
sudo ls /var/log/postgresql/
```

XII. Database Auditing

Enterprises databases require capabilities.

Install extension package :

```

sudo apt install \
postgresql-contrib -y

```

Connect :

```
sudo -u postgres psql
```

Enable extension in company_prod :

```

\c company_prod
CREATE EXTENSION pg_stat_statements;

```

Verify :

```
SELECT *
```

```
FROM pg_extension;
```

```
root@pg-primary:~# sudo -u postgres psql
psql (16.14 (Ubuntu 16.14-0ubuntu0.24.04.1))
Type "help" for help.

postgres=# \c company_prod
You are now connected to database "company_prod" as user "postgres".
company_prod=# CREATE EXTENSION pg_stat_statements;
CREATE EXTENSION
company_prod=# SELECT *
company_prod=# FROM pg_extension;
 oid |      extname      | extowner | extnamespace | extrelocatable | extversion | extconfig | extcondition 
-----+-----+-----+-----+-----+-----+-----+-----
 13610 | plpgsql           | 10       | 11            | f               | 1.0        |           | 
 16419 | pg_stat_statements | 10       | 2200          | t               | 1.10       |           | 
(2 rows)

company_prod=#
```

XIII. Monitoring Login Activity

Connect :

```
sudo -u postgres psql
```

Check sessions :

```
SELECT
```

```
pid,
```

```
username,
```

```
client_addr,
```

```
application_name,
```

```
state
```

```
FROM pg_stat_activity;
```

This becomes one of the most important queries in your DBA toolkit.

```
postgres=# SELECT
pid,
username,
client_addr,
application_name,
state
FROM pg_stat_activity;
 pid | username | client_addr | application_name | state 
-----+-----+-----+-----+-----
 61099 |          |             |                  | 
 61100 | postgres |             |                  | 
 63077 | app_user | 192.168.10.40 | psql              | idle 
103824 | postgres |             | psql              | active
 61096 |          |             |                  | 
 61095 |          |             |                  | 
 61098 |          |             |                  | 
(7 rows)
```

XIV. Role Review and Cleanup

Review :

```
\du
```

Questions :

- Does each role have a purpose ?
- Does each role have minimum privileges ?
- Are unnecessary superusers present ?

Expected :

Only :

- postgres
- dba_admin
- backup_operator
- app_user

```
postgres=# \du
                                List of roles
Role name | Attributes
-----|-----
app_user  |
backup_operator |
dba_admin | Superuser, Create role, Create DB
postgres  | Superuser, Create role, Create DB, Replication, Bypass RLS

postgres=#
```

XV. Unauthorized Access Simulation

From client-test

Attempt login :

```
psql -h pg-primary \
-U fake_user \
-d company_prod

root@client-test:~# psql -h pg-primary -U fake_user -d company_prod
Password for user fake_user:
psql: error: connection to server at "pg-primary" (192.168.10.20), port 5432 failed: FATAL: password authentication failed for user "fake_user"
connection to server at "pg-primary" (192.168.10.20), port 5432 failed: FATAL: password authentication failed for user "fake_user"
root@client-test:~#
```

Check logs :

```
sudo tail -f \
/var/log/postgresql/postgresql-*.log

root@pg-primary:~# tail -f /var/log/postgresql/postgresql-2026-06-13_163707.log
2026-06-13 16:37:09.183 UTC [113140] postgres@template1 LOG:  disconnection: session time: 0:00:00.002 user=postgres database=template1 host=[local]
2026-06-13 16:37:24.143 UTC [113215] [unknown]@[unknown] LOG:  connection received: host=192.168.10.40 port=50816
2026-06-13 16:37:26.495 UTC [113216] [unknown]@[unknown] LOG:  connection received: host=192.168.10.40 port=37332
2026-06-13 16:37:26.509 UTC [113216] fake_user@company_prod FATAL: password authentication failed for user "fake_user"
2026-06-13 16:37:26.509 UTC [113216] fake_user@company_prod DETAIL: Role "fake_user" does not exist.
Connection matched file "/etc/postgresql/16/main/pg_hba.conf" line 126: "host all all 192.168.10.0/24 scram-sha-256"
2026-06-13 16:37:26.511 UTC [113217] [unknown]@[unknown] LOG:  connection received: host=192.168.10.40 port=37338
2026-06-13 16:37:26.517 UTC [113217] fake_user@company_prod FATAL: password authentication failed for user "fake_user"
2026-06-13 16:37:26.517 UTC [113217] fake_user@company_prod DETAIL: Role "fake_user" does not exist.
Connection matched file "/etc/postgresql/16/main/pg_hba.conf" line 126: "host all all 192.168.10.0/24 scram-sha-256"
2026-06-13 16:42:07.141 UTC [113113] LOG:  checkpoint starting: time
2026-06-13 16:42:07.146 UTC [113113] LOG:  checkpoint complete: wrote 3 buffers (0.0%); 0 WAL file(s) added, 0 removed, 0 recycled; write=0.002 s, sync=0.001 s, total=0.006 s; sync files=2, longest=0.001 s, average=0.001 s; distance=0 kB, estimate=0 kB; lsn=0/225F588, redo lsn=0/225F550
```

XVI. Security Validation Tests

1. Test 1

Verify SSH access :

```
ssh david@pg-primary
```

2. Test 2

Verify firewall :

```
nmap pg-primary
root@client-test:~# nmap pg-primary
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-13 16:46 UTC
Nmap scan report for pg-primary (192.168.10.20)
Host is up (0.0017s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
5432/tcp   open  postgresql
MAC Address: 00:0C:29:83:3B:29 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 4.46 seconds
root@client-test:~#
```

3. Test 3

Verify PostgreSQL access :

```
psql -h pg-primary \
-U app_user \
-d company_prod
```

4. Test 4

Verify TLS :

```
SHOW ssl;
```

5. Test 5

Verify logging

Create test table :

```
CREATE TABLE audit.test(
id INT
);
```

Checks logs :

```
tail -f /var/log/postgresql/postgresql-2026-06-13_163707.log
root@pg-primary:~# tail -f /var/log/postgresql/postgresql-2026-06-13_163707.log
2026-06-13 16:58:09.682 UTC [117017] postgres@postgres LOG:  duration: 0.228 ms
2026-06-13 16:58:10.315 UTC [117049] [unknown]@[unknown] LOG:  connection received: host=[local]
2026-06-13 16:58:10.316 UTC [117049] postgres@company_prod LOG:  connection authenticated: identity="postgres" method=peer (/etc/postgresql/16/main/pg_hba.conf:118)
2026-06-13 16:58:10.316 UTC [117049] postgres@company_prod LOG:  connection authorized: user=postgres database=company_prod application_name=psql
2026-06-13 16:58:10.317 UTC [117017] postgres@postgres LOG:  disconnection: session time: 0:00:05.202 user=postgres database=postgres host=[local]
2026-06-13 16:58:45.115 UTC [117049] postgres@company_prod LOG:  statement: CREATE TABLE audit_test (id INT);
2026-06-13 16:58:45.117 UTC [117049] postgres@company_prod LOG:  duration: 2.167 ms
2026-06-13 16:58:52.149 UTC [117049] postgres@company_prod LOG:  duration: 2.021 ms
2026-06-13 16:59:55.463 UTC [117049] postgres@company_prod LOG:  duration: 1.100 ms
2026-06-13 16:59:57.231 UTC [117049] postgres@company_prod LOG:  duration: 1.006 ms
```

XVII. Security Baseline Documentation

Administrative Accounts	
Account	Purpose
postgres	Local DBA
dba_admin	Enterprise DBA

backup_operator	Backup Operations
app_user	Application Access
Allowed Ports	
Port	Service
22	SSH
5432	PostgreSQL
3000	Grafana
9090	Prometheus